Building an Enterprise SOC Lab: From IDS to SIEM with Automated Threat Response

Final SIEM/SOC Capstone Project Report

Author: Yumanang Sallah

Credentials: SOC Analyst | CEH | Google Cybersecurity | Splunk SIEM | Wazuh SIEM/XDR

LinkedIn:

www.linkedin.com/in/yumanang-sallah-9ba444189

Portfolio:

https://github.com/sallah-sec/cybersecurity-lab.git

Email: sallahyumanang1@gmail.com

Programme / Institution: Self-Trained Cybersecurity Professional

Project version: 1.0

Environment: Isolated enterprise-style security operations laboratory

Contents

1. Executive Summary..... 3
2. Architecture and Data Flows..... 3
2.1 Asset Register and Network Overlay..... 4
2.2 Golden Image Strategy..... 5
3. Use Cases and Detection Scenarios..... 5
3.1 Use Case 1 — FIM detects a change to /etc/passwd 5
3.2 Use Case 2 — VirusTotal detects EICAR and Wazuh removes it..... 7
3.3 Use Case 3 — Suricata detects a port scan..... 9
3.4 Use Case 4 — Caldera credential-access emulation detected by Wazuh..... 10
4. Splunk Dashboards and Correlation..... 14
5. Transport Layer Validation (rsyslog)..... 16
6. Bonus Evidence: Vulnerability Detection..... 17
7. Challenges, Failure Modes, and Mitigations..... 18
7.1 The "Black Screen" Boot Failure..... 18
7.2 ZeroTier IP Conflict..... 18
7.3 rsyslog Configuration Warning..... 18
8. Conclusion and Future Improvements..... 19

1. Executive Summary

The objective of this capstone was to build a controlled SOC laboratory that behaves like a small enterprise monitoring environment rather than a collection of disconnected security tools. This project represents the culmination of a deliberate career transition from a background in Biochemistry into the field of Cybersecurity, specifically specializing in Security Operations (SOC) and Threat Detection.

The lab begins with a private ZeroTier overlay that allows the virtual machines to communicate without exposing the experiment directly to an uncontrolled network. Suricata provides network intrusion detection, while Wazuh Manager centralizes endpoint events from Linux and Windows agents, applies rules, tracks file-integrity changes, and coordinates active response. The VirusTotal integration enriches suspicious file events with reputation context, while MITRE Caldera provides authorized adversary emulation. Splunk Enterprise provides the analyst-facing layer, ingesting Wazuh and Suricata logs via a Universal Forwarder.

The central engineering result is an end-to-end loop: Generate signal → collect telemetry → normalize and enrich → detect → investigate → contain → preserve evidence → improve the rule. Four primary scenarios validate the design: a change to /etc/passwd, detection of the EICAR test artifact, a Suricata port-scan alert, and a Caldera-emulated credential-access behavior detected by a custom Wazuh rule.

2. Architecture and Data Flows

The laboratory is organized into six layers:

- **Connectivity and access:** ZeroTier provides the private overlay (Network ID: af78bf9436bfa4c0); Remmina supports SSH and RDP administration.
- **Signal generation:** Suricata, Linux audit/system logs, Windows event logs, Wazuh FIM, and Caldera activity.
- **Transport and collection:** rsyslog transports selected network and system logs; Wazuh agents send endpoint telemetry to the Wazuh Manager.
- **Detection and enrichment:** Wazuh rules, FIM, VirusTotal integration, Sigma-derived rules, and Active Response.
- **Analytics and presentation:** Splunk Universal Forwarder sends Wazuh alerts and Suricata events to Splunk Enterprise.
- **Response and improvement:** Analysts investigate, contain, preserve evidence, document outcomes, and tune detections.

2.1 Asset Register and Network Overlay

The lab consists of four primary virtual machines, managed via QEMU/KVM and interconnected via the ZeroTier overlay.

Hostname	Operating System	Role	ZeroTier IP
cityzen	Ubuntu (Wazuh Manager)	SIEM/Wazuh Manager, rsyslog Server, Splunk Enterprise	10.147.20.123
caldera-c2	Kali Linux	Caldera C2 (Adversary Emulation)	10.147.20.85
centos	CentOS Stream 10	Target Endpoint / Wazuh Agent	10.147.20.87
SurfaceGo-Win10	Windows 10 Pro	Wazuh Agent, Splunk Universal Forwarder	10.147.20.151

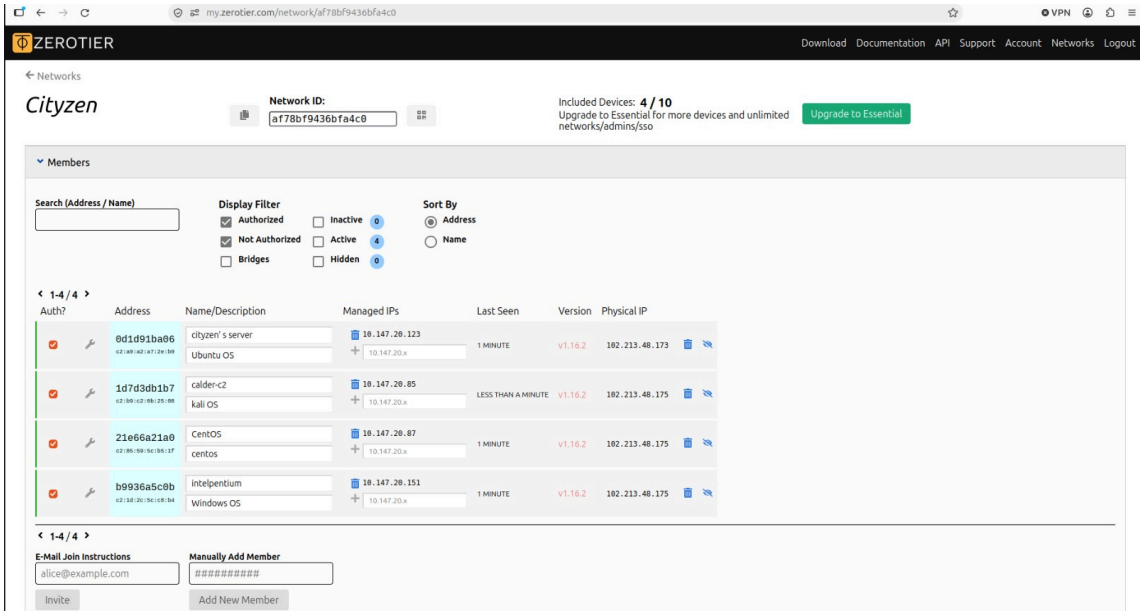


Figure 1: ZeroTier Central Members table showing all four authorized lab assets communicating on the 10.147.20.0/24 overlay network.

2.2 Golden Image Strategy

To ensure repeatability and safe rollback, a "Golden Image" strategy was implemented for the Caldera C2 server. After a clean installation of Kali Linux, the VM was cloned. The original caldera-c2 was used for the project, while the caldera-c2-clone-GOLDEN was retained as a pristine baseline.

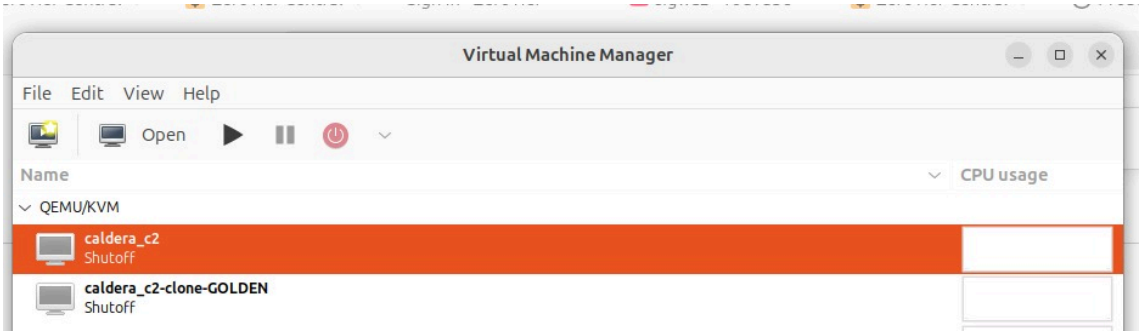


Figure 2: QEMU/KVM Manager showing the active Caldera VM and the shut-off Golden Clone.

3. Use Cases and Detection Scenarios

3.1 Use Case 1 — FIM detects a change to /etc/passwd

Objective: Detect an integrity change to a sensitive Linux identity file and attribute it to an agent.

Test procedure: A controlled, reversible change was made to /etc/passwd on the centos agent. Wazuh FIM detected the modification and generated Rule 550.

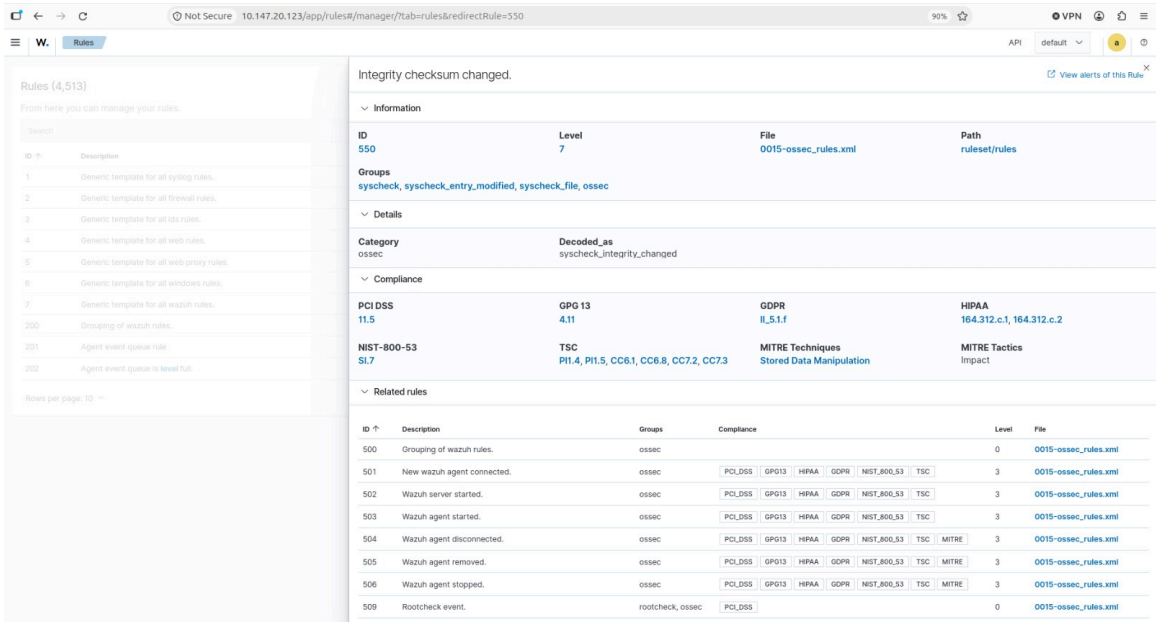


Figure 3: Wazuh Ruleset showing Rule 550 ("Integrity checksum changed") and its compliance mappings.

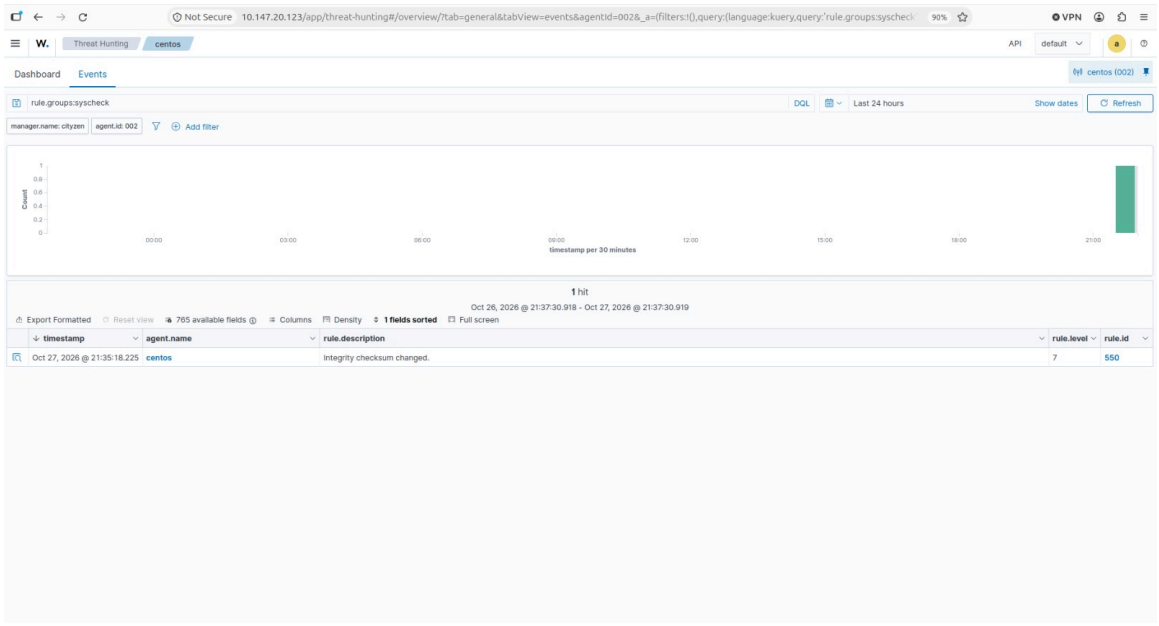


Figure 4: Wazuh Threat Hunting dashboard showing Rule 550 triggered on the centos agent after a modification to /etc/passwd.

Analyst interpretation: The alert identifies an integrity change but does not by itself prove malicious activity. The analyst must correlate the timestamp with process, authentication, and sudo records. This scenario supports detection of T1098 Account Manipulation.

3.2 Use Case 2 — VirusTotal detects EICAR and Wazuh removes it

Objective: Validate file reputation enrichment using the EICAR test artifact.

Test procedure: The EICAR test string was created on the centos endpoint. Wazuh calculated the hash, sent it to VirusTotal, and received the enrichment result (66 engines flagged it).

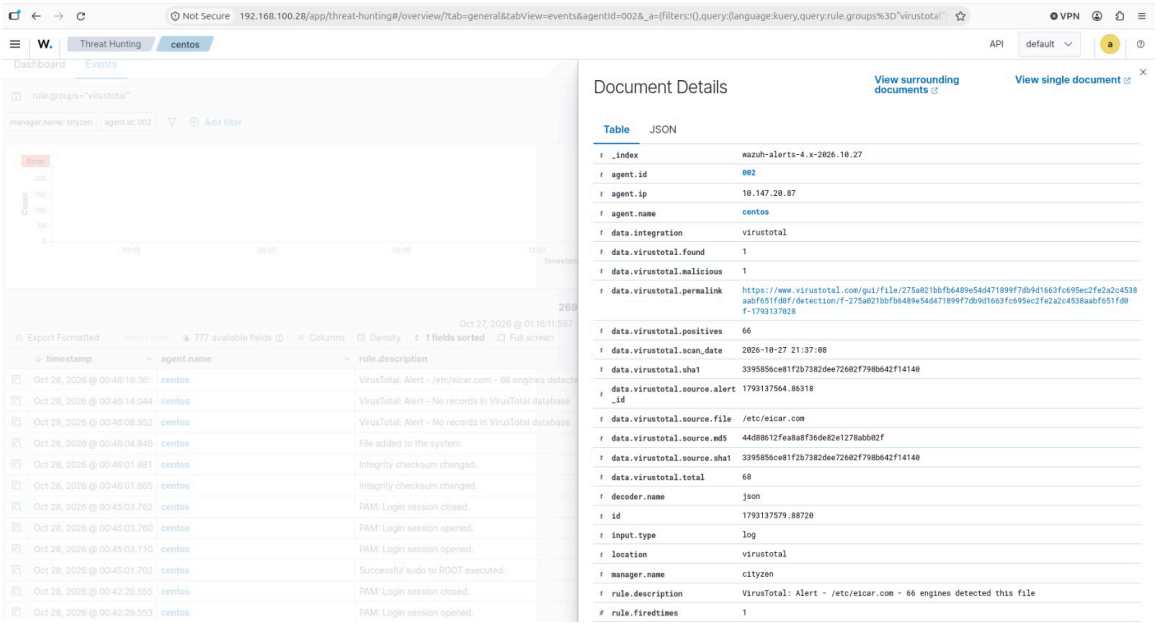


Figure 5: Wazuh Document Details showing the VirusTotal integration identifying /etc/eicar.com as malicious (Rule 87105, Level 12).

Representative Wazuh alert (JSON):



```
  "_source": {
    "agent": { "ip": "10.147.20.87", "name": "centos", "id": "002" },
    "data": {
      "integration": "virustotal",
      "virustotal": {
        "malicious": "1",
        "positives": "66",
        "source": { "file": "/etc/eicar.com", "sha1": "339585..." }
      }
    },
    "rule": {
      "level": 12,
      "description": "VirusTotal: Alert - /etc/eicar.com - 66 engines detected this file",
      "id": "87105"
    }
  }
}
```

Analyst interpretation: The EICAR response validates the integration but is not evidence of a real malware infection. The analyst must verify the path, hash, source host, and response script.

3.3 Use Case 3 — Suricata detects a port scan

Objective: Generate authorized reconnaissance against a designated lab target and confirm that Suricata records the signature, source, destination, and network context.

Test procedure: A low-rate Nmap scan was executed against the centos target from the kali sensor.

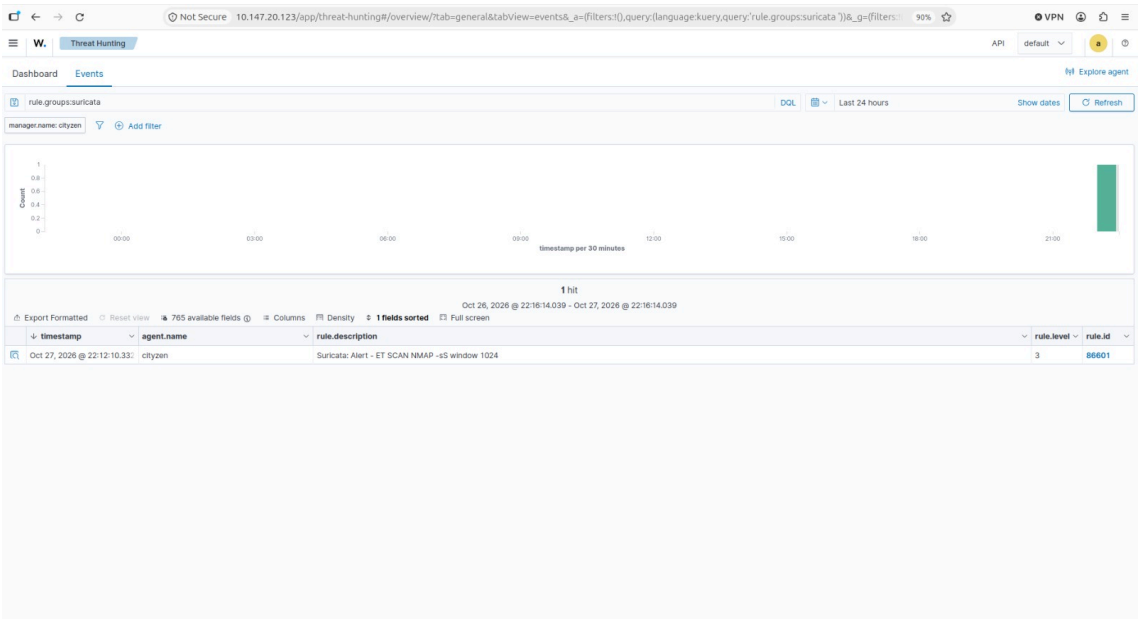


Figure 6: Wazuh dashboard showing a Suricata alert for an authorized Nmap scan ("ET SCAN NMAP -sS window 1024") generated on the cityzen sensor.

Analyst interpretation: The alert indicates reconnaissance behavior, not necessarily compromise. Correlate source identity, scan duration, and ports targeted. This scenario maps to T1046 Network Service Scanning.

3.4 Use Case 4 — Caldera credential-access emulation detected by Wazuh

Objective: Use Caldera to emulate a credential-access behavior against the centos endpoint and detect the resulting process telemetry.

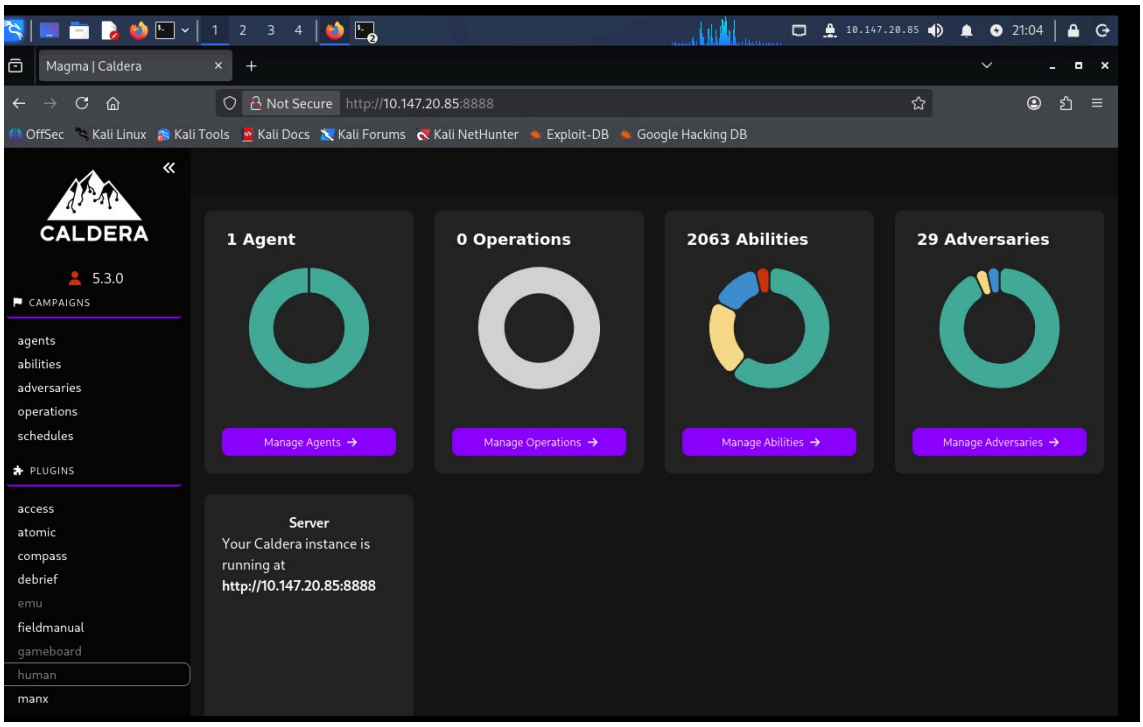


Figure 7a: Caldera Dashboard overview showing the C2 server is active with 2063 abilities loaded and 1 agent connected.

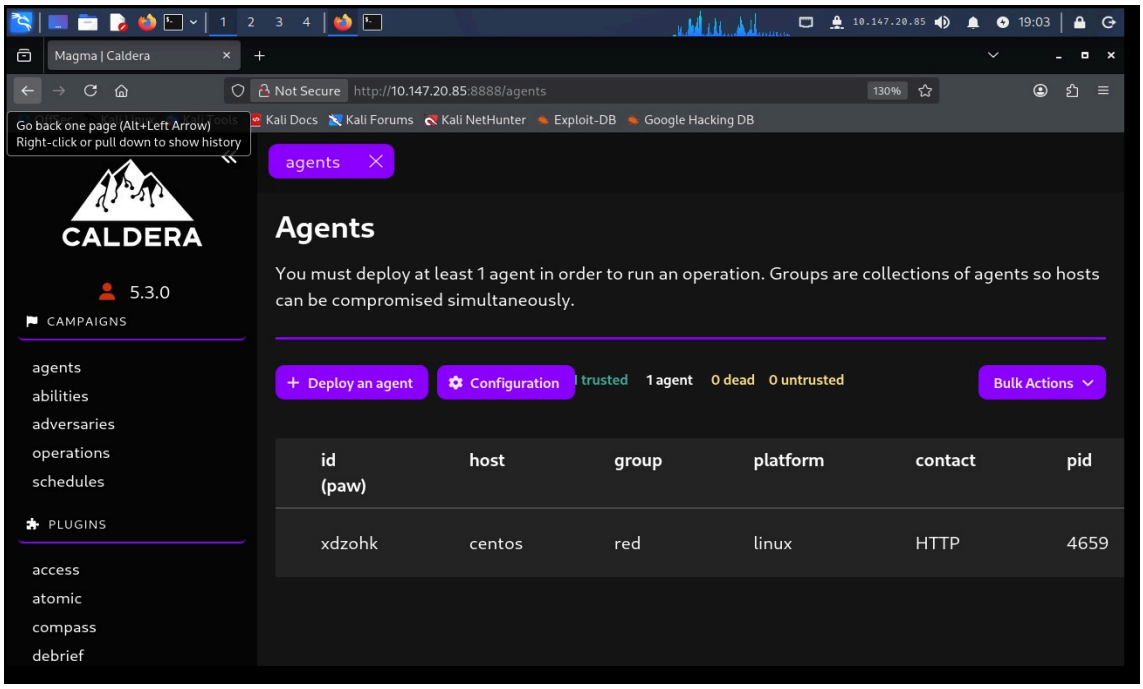


Figure 7b: Caldera Web UI (v5.3.0) running on the caldera-c2 VM, showing the deployed Sandcat agent.

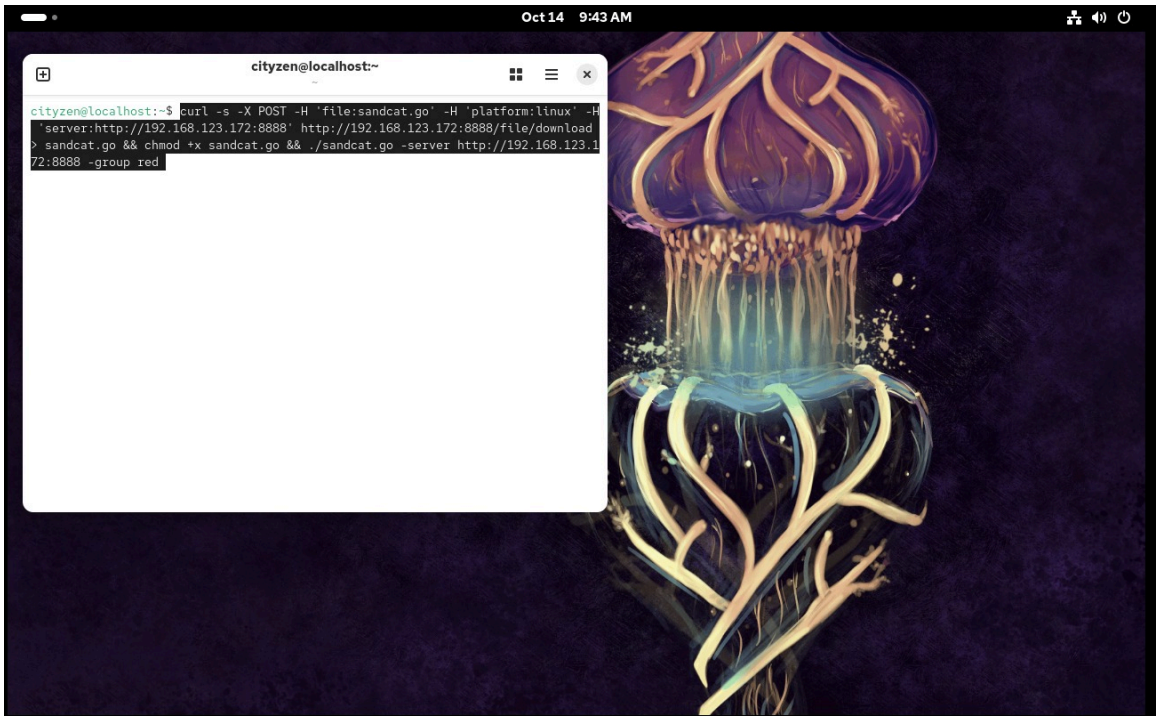


Figure 8: Terminal showing the execution of the Sandcat agent deployment command on the target CentOS endpoint.

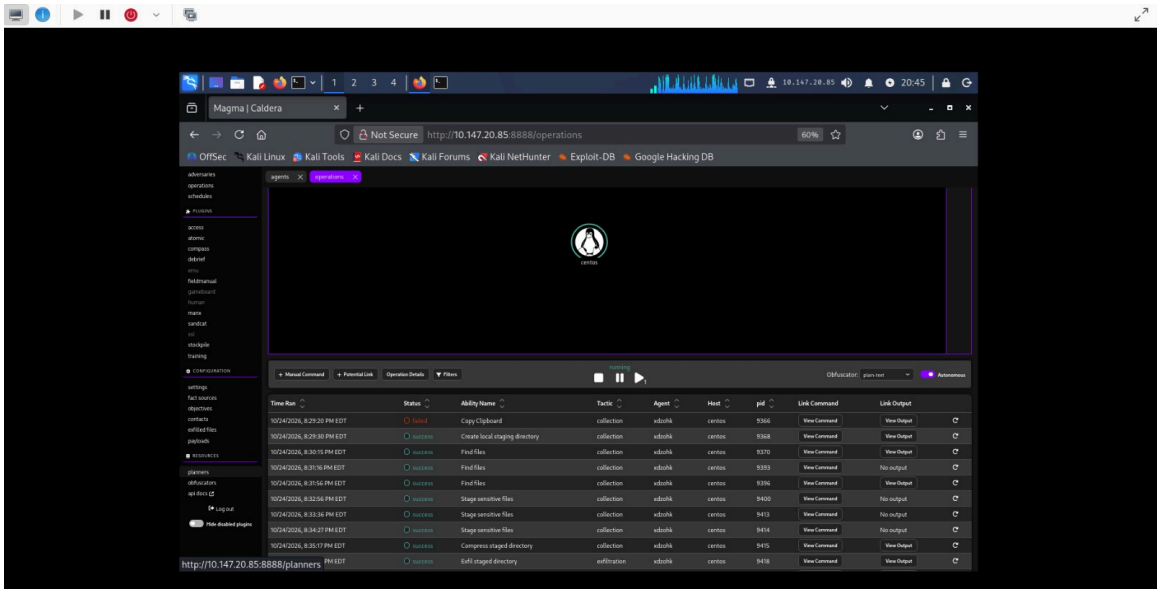


Figure 9: Caldera operation log showing successful execution of adversary emulation techniques against the CentOS agent.

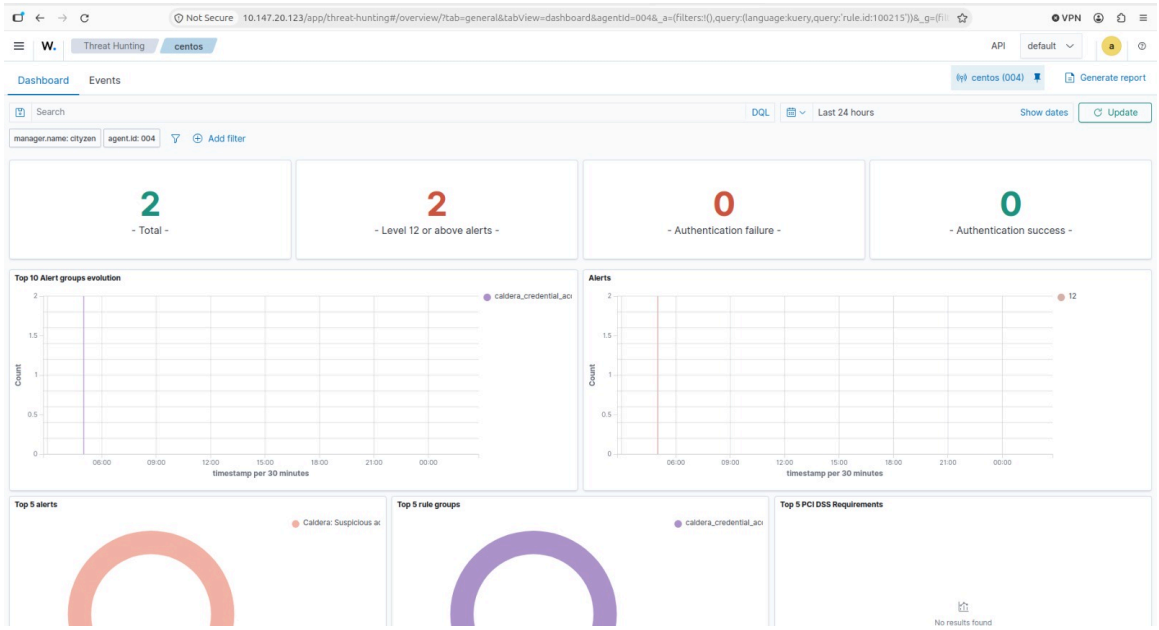


Figure 10: Wazuh Threat Hunting dashboard showing a Level 12 alert triggered by the custom Sigma-derived rule (Rule group: caldera_credential_acc...).

Representative Wazuh alert (JSON):



```
{
  "_source": {
    "agent": { "name": "centos" },
    "rule": {
      "id": "100215",
      "level": 12,
      "description": "Sigma: Suspicious Credential Access Utility Execution",
      "mitre": { "id": ["T1003"], "tactic": ["credential-access"] }
    },
    "data": {
      "win": { "eventdata": { "image": "C:\\LabTools\\procdump.exe" } }
    }
  }
}
```

Analyst interpretation: The detection confirms that the Sigma-derived rule successfully identified the Caldera emulation. The mapping must follow observed behavior (T1003 OS Credential Dumping).

4. Splunk Dashboards and Correlation

Splunk Enterprise serves as the analyst-facing layer. A Universal Forwarder on the Wazuh Manager sends alerts.json and eve.json into separate indexes.

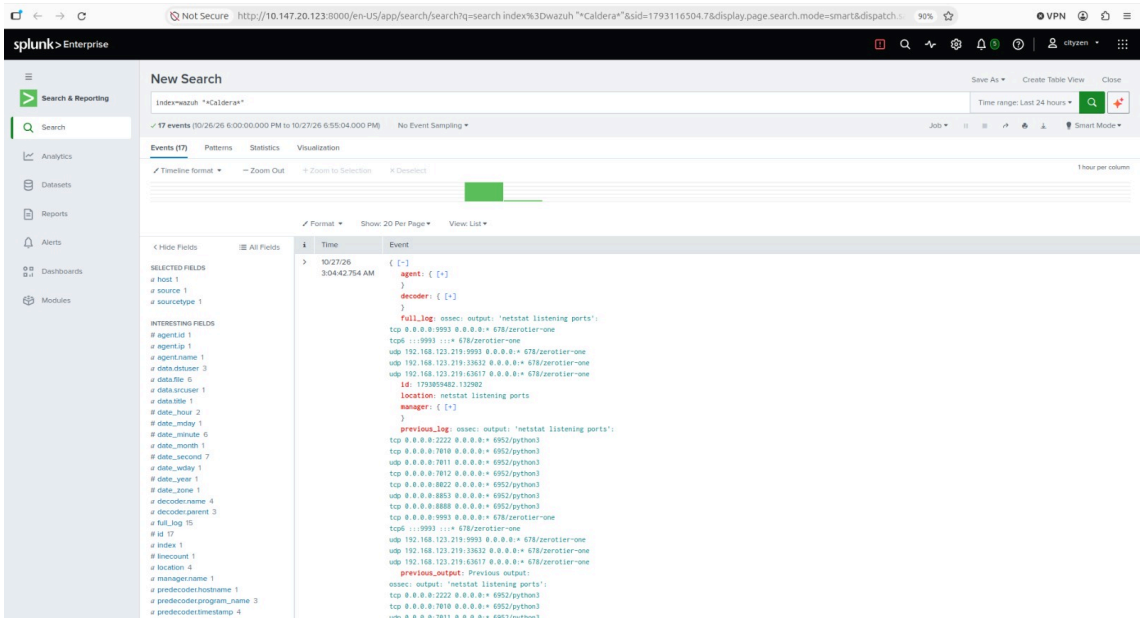


Figure 11: Splunk Enterprise raw search confirming the C2 telemetry was successfully forwarded and indexed.

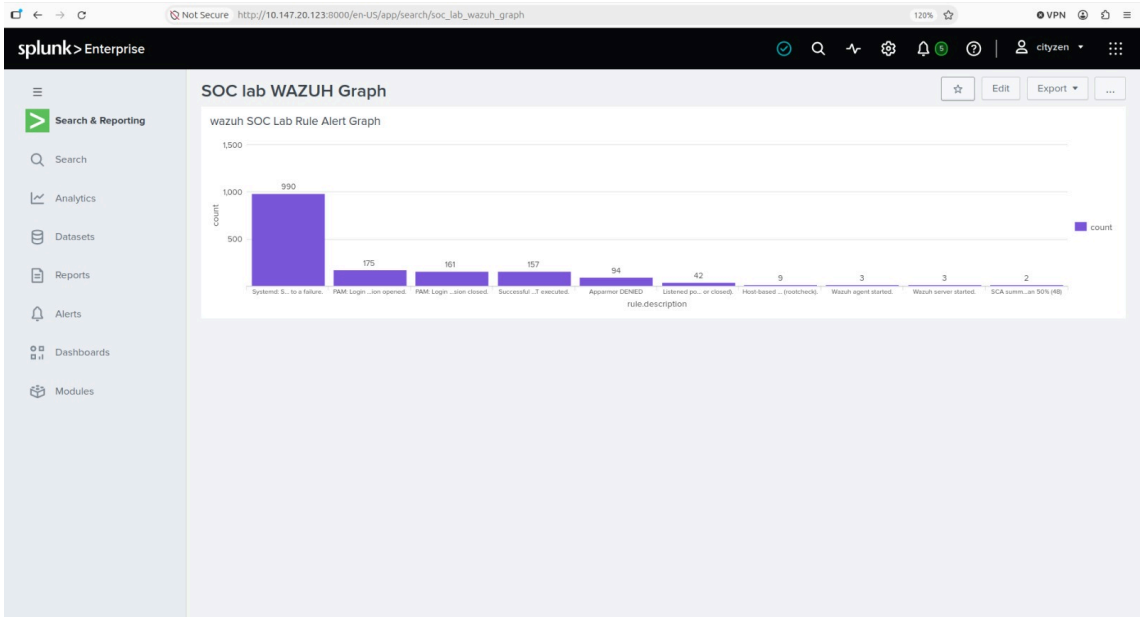


Figure 12: Splunk Dashboard visualization showing the top 10 triggered Wazuh rules by volume, aiding in alert triage and noise reduction.

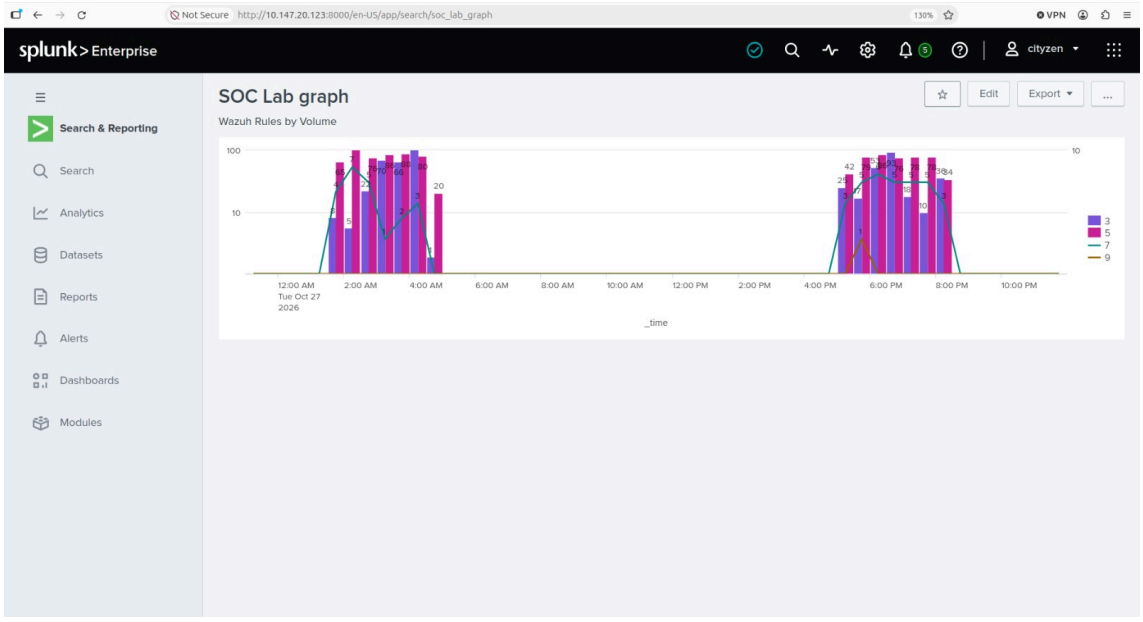


Figure 13: Splunk timechart visualizing the volume of Wazuh alerts over time.

5. Transport Layer Validation (rsyslog)

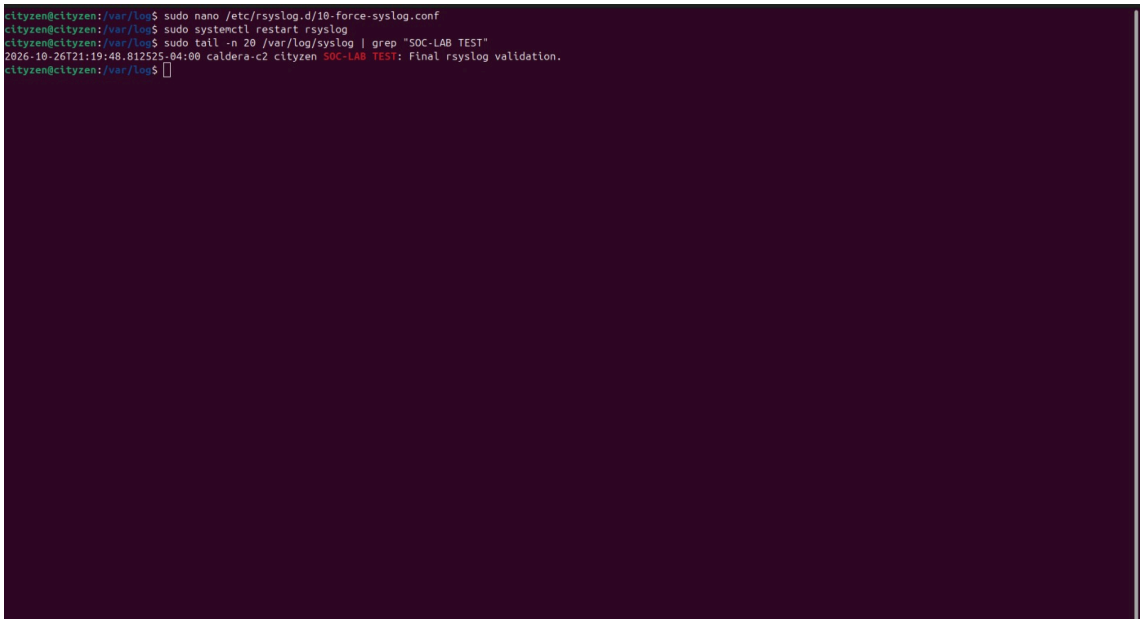


Figure 14: Verification that the caldera-c2 VM successfully forwarded a test log message to the cityzen rsyslog collector.

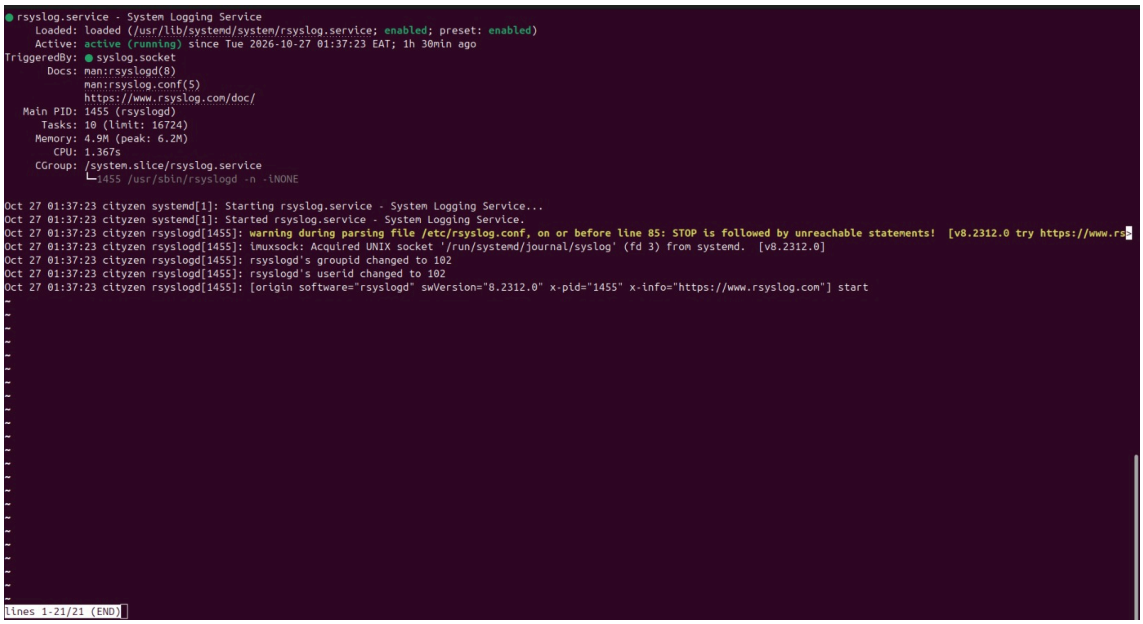


Figure 15: systemctl status rsyslog confirming the logging service is active and running on the Wazuh Manager.

6. Bonus Evidence: Vulnerability Detection

Although not part of the initial four use cases, the Wazuh Vulnerability Detection module successfully identified unpatched CVEs on the CentOS target, adding significant value to the SOC lab.

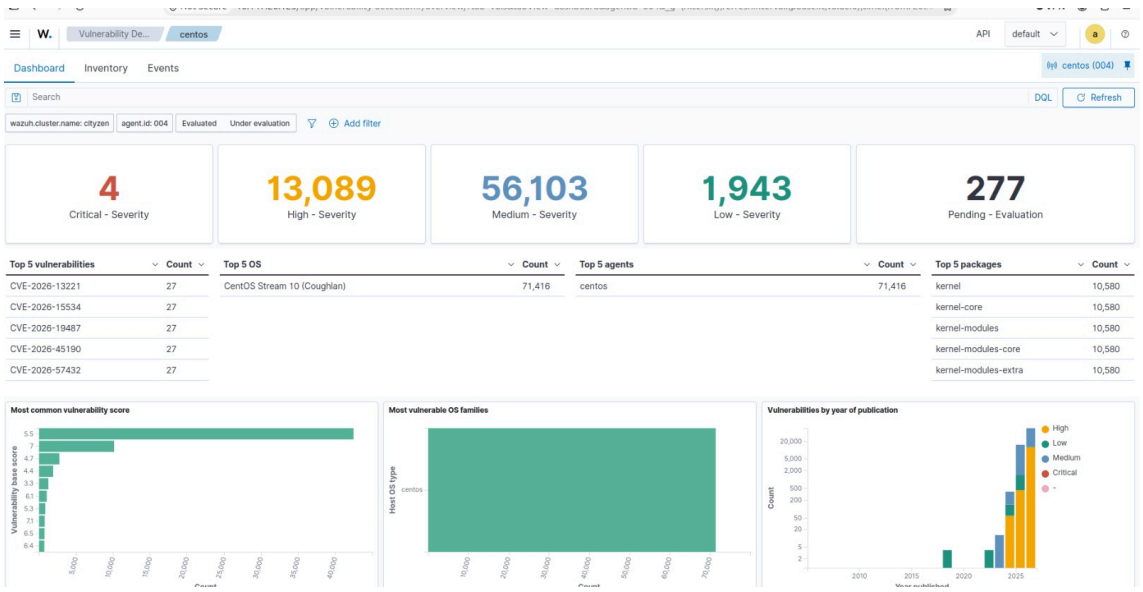


Figure 16: Wazuh Vulnerability Detection module identifying CVEs on the CentOS Stream 10 target.

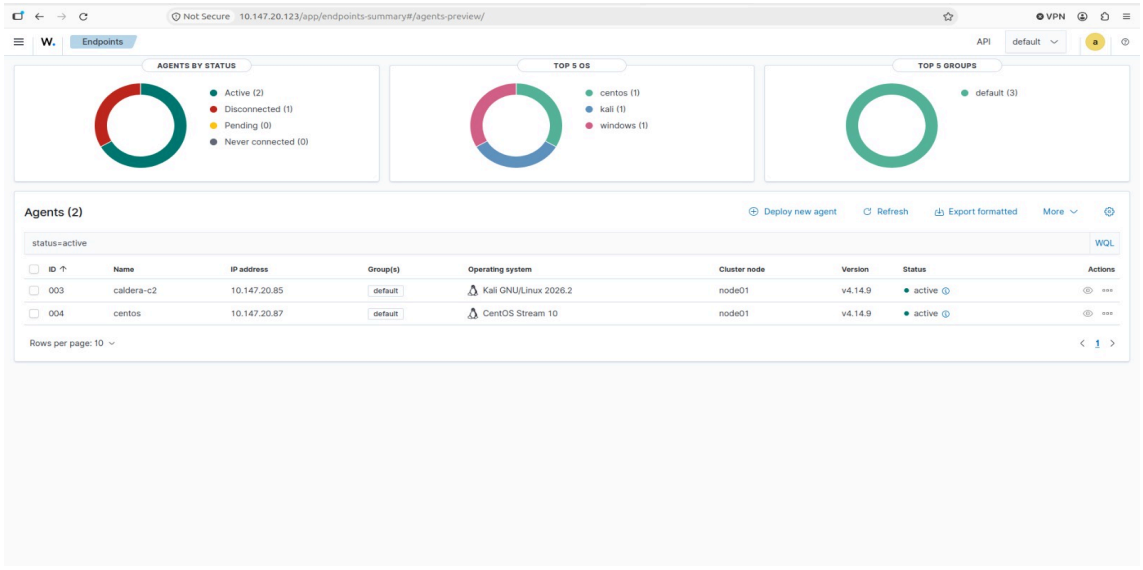


Figure 17: Wazuh Endpoints page showing both the Caldera C2 and CentOS agents reporting as active.

7. Challenges, Failure Modes, and Mitigations

7.1 The "Black Screen" Boot Failure

Challenge: The initial Caldera VM (hosted on an Intel Pentium host) failed to boot, displaying a black screen after the "display output not active" message.

Mitigation: The issue was traced to missing hardware virtualization support and a conflict with the QXL graphics driver. The VM was rebuilt inside the primary QEMU/KVM environment using a Golden Image strategy to ensure a clean, reproducible baseline.

7.2 ZeroTier IP Conflict

Challenge: Initial documentation assumed a 10.137.112.x subnet, but the ZeroTier dashboard showed the actual network was provisioned on 10.147.20.x.

Mitigation: The asset register was updated to reflect the verified ZeroTier Central Members table (Figure 1).

7.3 rsyslog Configuration Warning

Challenge: The rsyslog service threw a warning: STOP is followed by unreachable statements!.

Mitigation: The configuration was reviewed, and the test log (SOC-LAB TEST) successfully arrived at the collector. The warning was documented as a benign configuration artifact.

8. Conclusion and Future Improvements

This project demonstrates that an effective SOC is a system of connected controls rather than a single product. ZeroTier and Remmina establish controlled access. rsyslog, Suricata, and Wazuh create visibility. FIM and VirusTotal add endpoint integrity and enrichment. Caldera provides an authorized way to test coverage.

The four use cases show different classes of detection: FIM identifies a change requiring context; VirusTotal validates enrichment and safe automated response; Suricata identifies network discovery; and Caldera validates whether endpoint telemetry can identify adversary behavior.

Professional Reflection:

Transitioning from a background in Biochemistry to Cybersecurity has provided a unique analytical advantage. The methodologies required to track biochemical pathways, monitor systemic changes, and maintain rigorous evidence logs translate directly to SOC operations—treating network telemetry much like a biological system, looking for baseline anomalies, and understanding how a single malicious event can cascade into a systemic breach. This lab serves as tangible proof of self-trained technical competency, bridging the gap between analytical theory and operational SOC readiness.

Future Improvements:

MISP / TheHive: Integrate for centralized indicator management and case management.

SOAR: Automate enrichment and approved response playbooks with human approval gates.

Detection-as-code: Store Sigma and Wazuh rules in version control with automated testing.